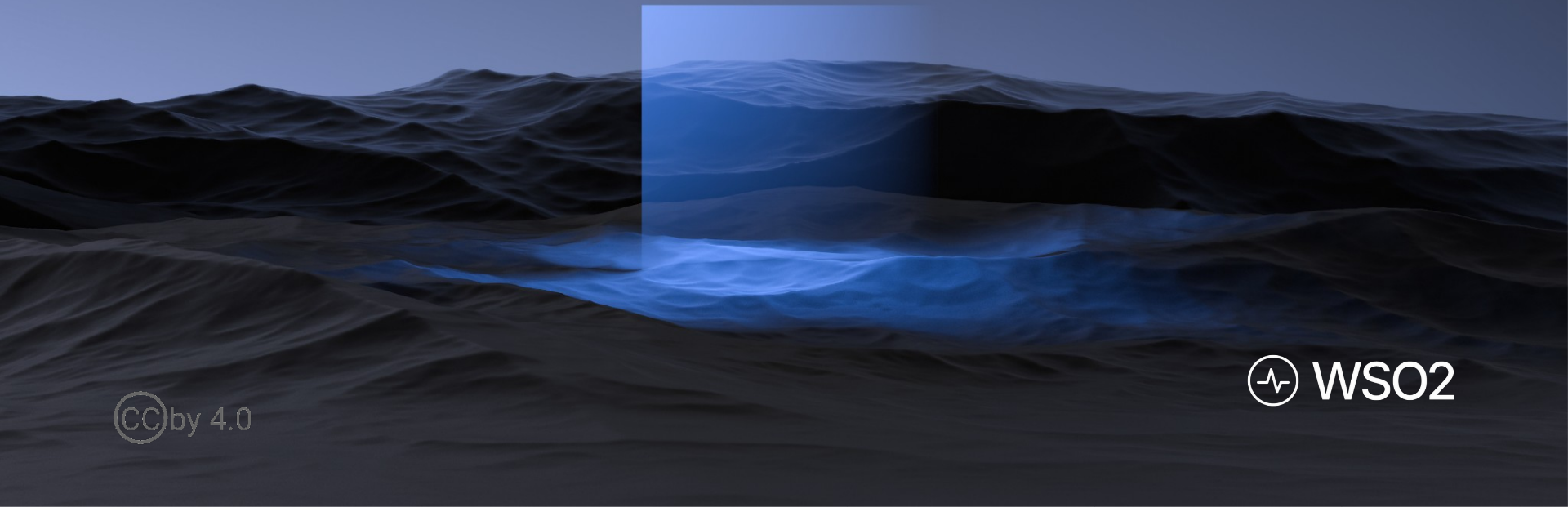
API Governance



CC by 4.0

WSO2

Objectives

By the end of this module, attendees will have a basic understanding of:

- What API governance is
- Why API governance is important
- Key WSO2 API-M governance concepts
- How and when API compliance is evaluated
- How to use administrative governance capabilities
- How to use governance capabilities as an API creator or publisher
- How to use governance features with APICTL
- The inner workings of synchronous and asynchronous governance evaluation

Understanding API Governance

WSO2

What is API Governance ?

In simple terms,

> API-M Governance refers to setting rules, policies, and processes to ensure that APIs are managed (developed, deployed, and consumed) in a secure, consistent, and compliant way across an organization.

Why is it Important ?

- Organizational admins often lack control and visibility over how developers manage their APIs using the WSO2 API Manager.
- This has led to many issues

    APIs do not adhere to organization-defined standards

    APIs without proper security are being moved to prod

    APIs not supporting business objectives (eg, - Making APIs easy to use with proper documentation).

Governance capabilities provide a way for organizational admins to **enforce policies, monitor compliance, and gain visibility** into how developers manage APIs within the WSO2 API Manager (Control Plane)

Governance Concepts in API-M

WSO2

Ruleset

- A ruleset is a **collection of rules**
- Each ruleset,

  Has a unique name

  Bounded to a specific API type (for now we only support **REST and Async** types)

  Contain **rules with different severities** (Error, Warn, Info)

- The rules within a ruleset **validate a specific aspect of the API**

  API Definition – The OpenAPI or AsyncAPI definition.

  API Metadata – WSO2 API-M's interpretation of an API (**api.yaml**)

  API Documentation – Documentation metadata.

Governance Policy

A label is a tag that can be attached to a specific governance artifact to categorize them based on specific criteria

- A policy is a **collection of rulesets**
- Policy Attachment

  Can be attached to one or more labels

  When a policy is assigned to a label, it is automatically applied to all APIs associated with that label

  Organizations also have the ability to define organization-wide policies that apply to all APIs
- Policy Enforcement Criteria

  When to Enforce - API Create, API Update, API Deploy, API Publish

  What to Do

  can be configured to take specific actions based on the severity of rule violations

  Block – Prevents the API operation. (Only for API Deploy and API Publish)

  Notify – Allow the operation to proceed but notify developer by updating the compliance dashboard.

Compliance Evaluation of APIs

Compliance Evaluation of APIs

- APIs are evaluated based on governance policies that enforce rulesets to ensure adherence to organizational standards. These policies are categorized into two types:
    - Global Policies – Automatically applied to all APIs.
    - Labeled Policies – Applied when specific labels are assigned to an API.
- Policy Execution and Evaluation take place during following API lifecycle events depending on policy configuration:
    - API Creation
    - API Updates
    - API Revision Creation and Deployment
    - API Publishing

Compliance Evaluation of APIs

- Blocking vs. Non-Blocking Compliance Checks can be configured by administrators based on enforcement needs:

  If a policy is configured as blocking, API creators cannot proceed with the action until all compliance requirements are met. Blocking policies are only enforceable during the API Publish and Deploy stages.

  If a policy is non-blocking, API actions can proceed while the compliance check runs in the background. The results will be displayed in the compliance dashboard once the evaluation is complete. By default, the background compliance check runs every 2 minutes if a change has been detected.

Using API-M Admin Governance Capabilities

WSO2

Writing Your Own Ruleset

- API-M uses the **WSO2 Rule Validator as the validation engine and you should use its syntax for rulesets**.
- This syntax is quite similar to the Stoplight Spectral syntax.
- WSO2 Rule Validator is a,

    JSON/YAML linter

    Java implementation of Stoplight Spectral.

    Provides a **subset of the functionalities offered by Spectral**.

    More info

        Rule Validator Documentation

        Rule Validator Codebase

Creating a Ruleset

- Done through the Admin Portal https://localhost:9443/admin
- Navigate to **Governance → Ruleset Catalog → Create Ruleset**
- Provide the following information

  Name - Name of the ruleset.

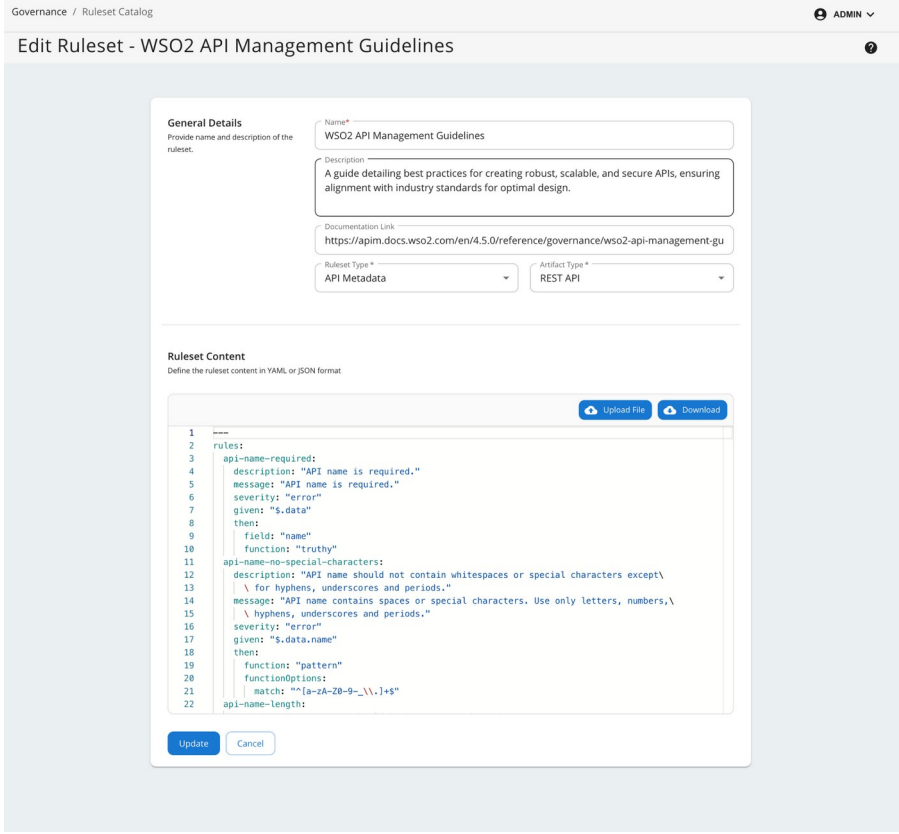
  Ruleset Type - Whether the ruleset contains rules for API definition, API meatada or API documentation.

  Artifact Type - The type of API which the ruleset applies to.

  Ruleset Content – The content of the ruleset.

- Click **Create**

Creating a Ruleset



Default Rulesets

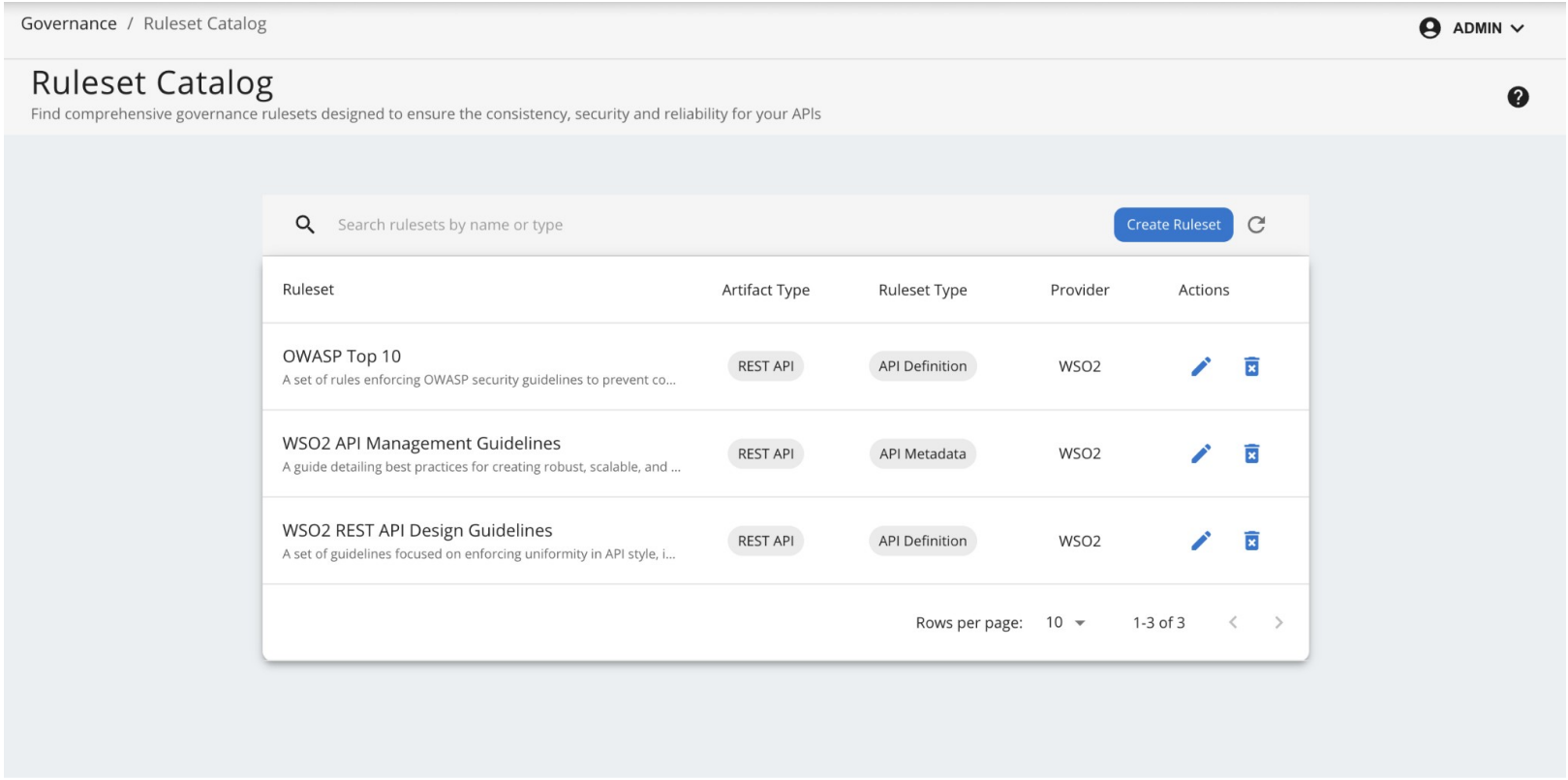
- WSO2 API-M comes with a set of default rulesets that cover common governance aspects

  WSO2 API Management Guidelines - An API Metadata ruleset that applies to REST APIs and covers general API management guidelines.

  WSO2 REST API Design Guidelines - An API Definition ruleset that applies to REST APIs and covers design best practices.

  OWASP Top 10 - An API Definition ruleset that applies to REST APIs and covers best practices for securing APIs against OWASP Top 10 vulnerabilities.

Default Rulesets



Creating a Label

- Done through the Admin Portal https://localhost:9443/admin
- Navigate to **Labels** section on admin portal and add a new label
- Provide the following information

    Name – Provide a name for the label

    Description - Provide an optional description

Creating a Governance Policy

- Done through the Admin Portal https://localhost:9443/admin
- Navigate to **Governance → Policies → Create Policy**
- Provide the following information

  Name – Provide a name for the governance policy.

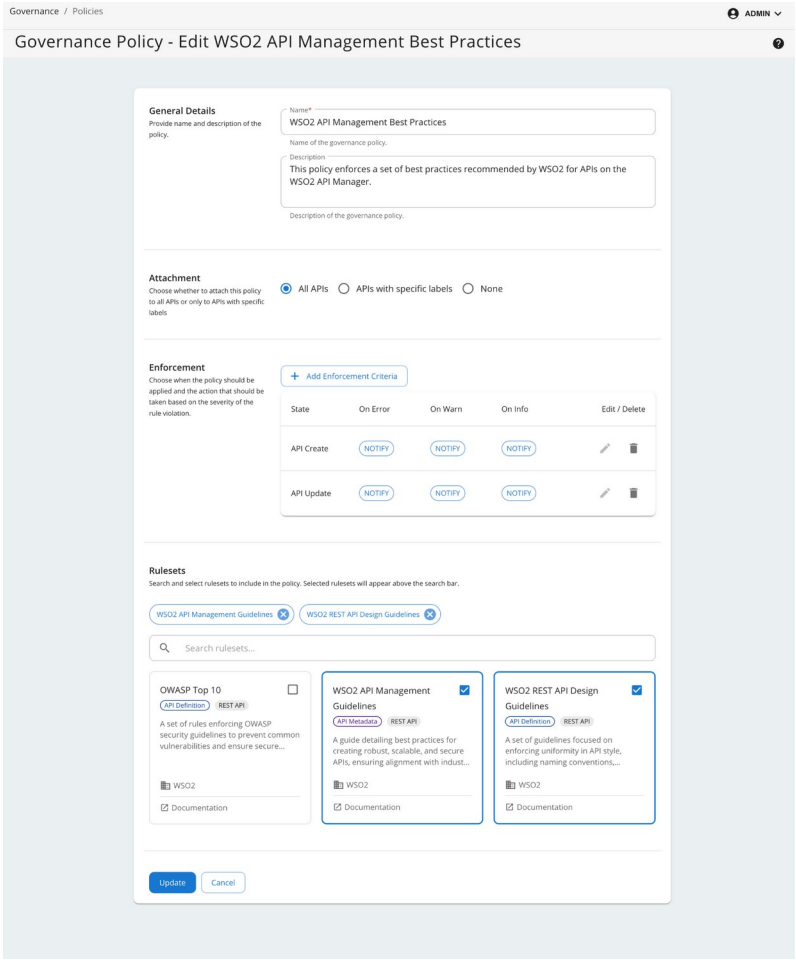
  Attachment – Specify whether the policy applies to all APIs or only those with a specific label.

  Add Enforcement Criteria – Define when to enforce the policy and what actions to take based on rule violations.

  Rulesets – Select the list of rulesets to include in the policy.

  Click Create – Finalize and create the governance policy.

Creating a Governance Policy



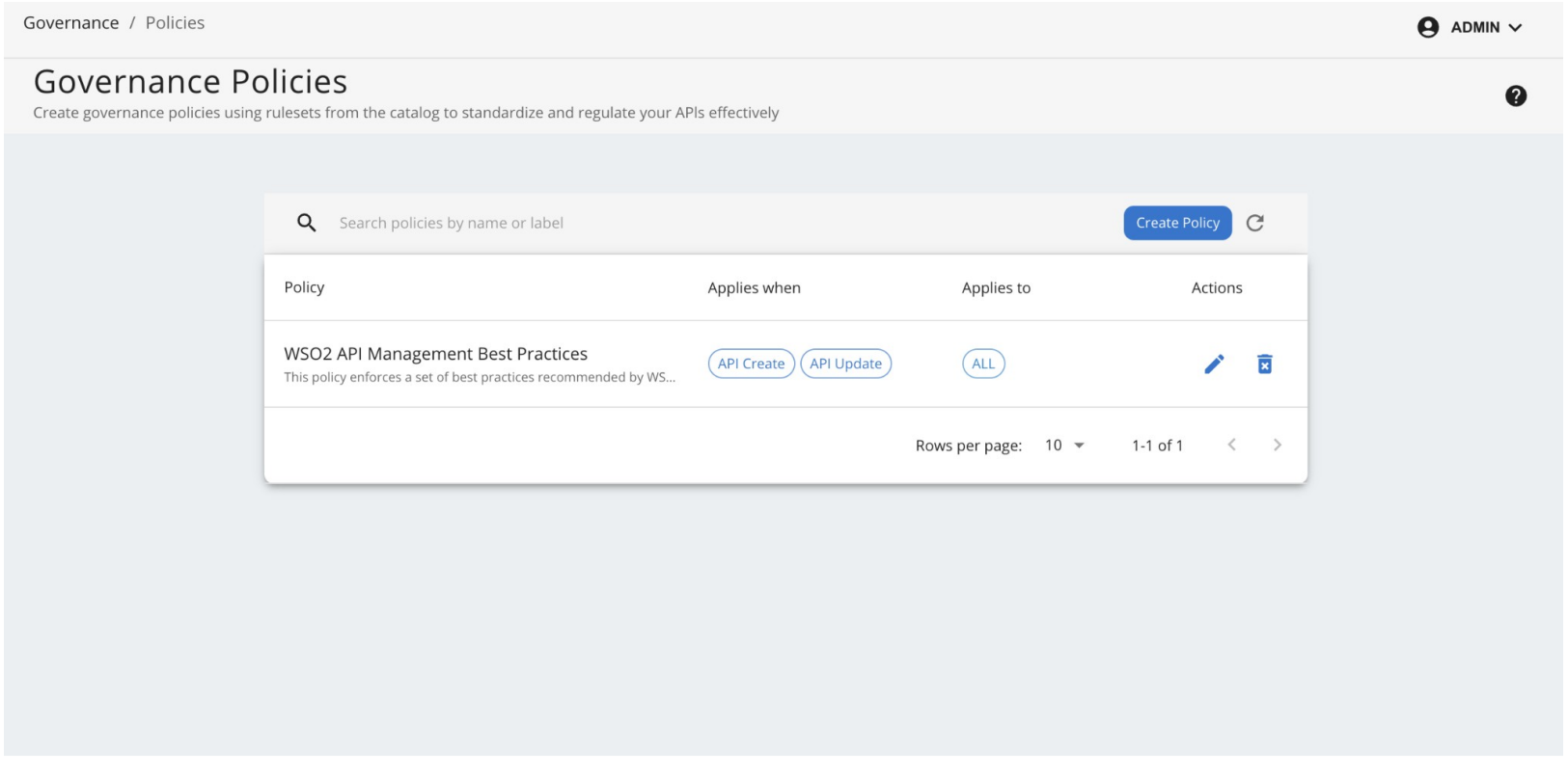
Default Policy

- WSO2 API Manager comes with a default governance policy named **WSO2 API Management Best Practices**
- It is configured to trigger during **API create** and **update** and **does not block developers** (notify mode) includes

    WSO2 API Management Guidelines ruleset

    WSO2 REST API Design Guidelines ruleset

Default Policy



Admin Compliance Dashboard

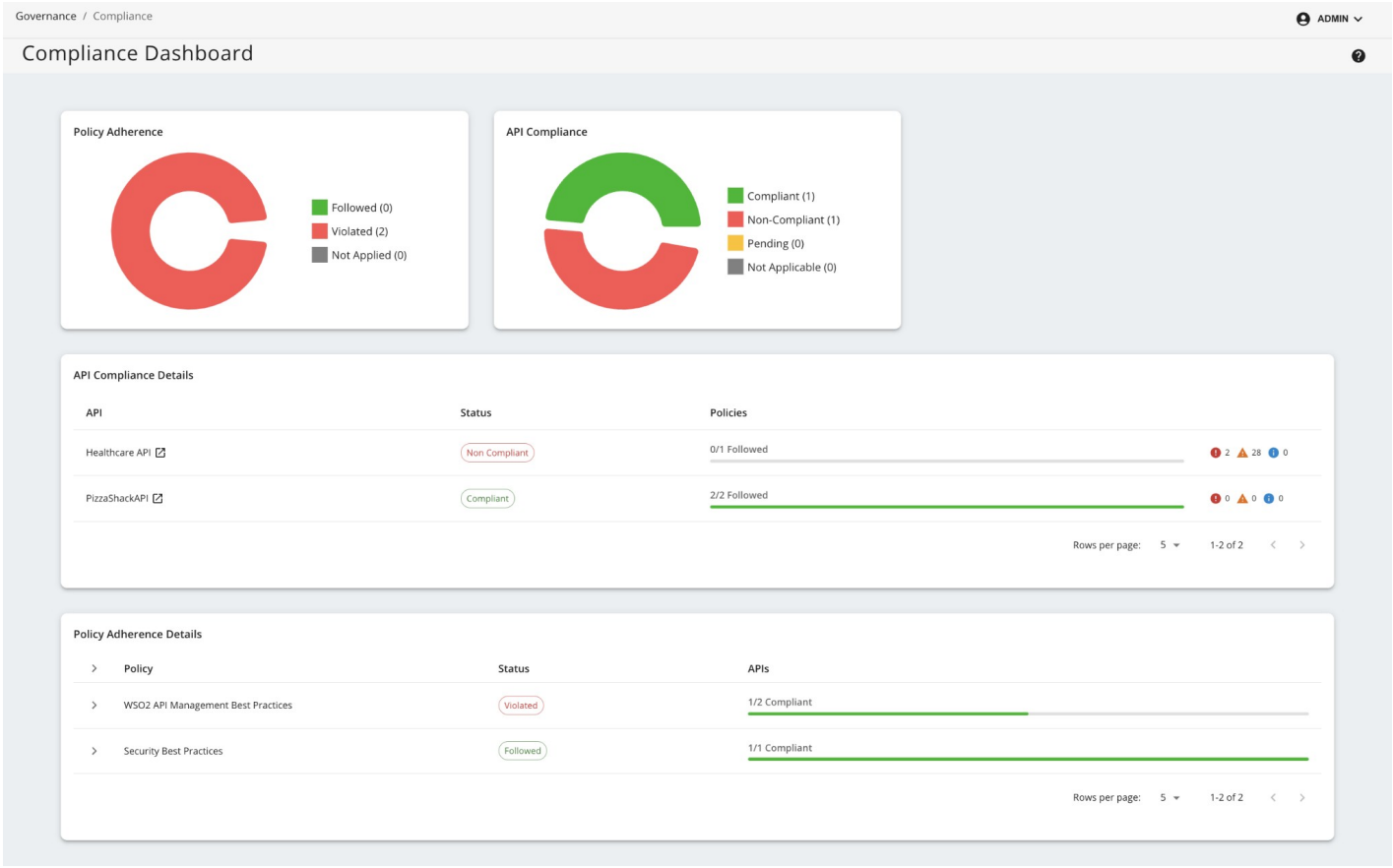
- The Compliance Dashboard provides a comprehensive view of the compliance status of APIs within the organization
- To access the dashboard,

  Log in to the API Manager Admin Portal https://localhost:9443/admin

  Go to the **Governance** section in the main menu.

  Click **Compliance** to view the compliance status of APIs.

Admin Compliance Dashboard



Using API Creator/Publisher Governance Capabilities

WSO2

Labelling APIs

- API creators can label their APIs appropriately to ensure the relevant governance policies are applied.
- To assign labels to an API

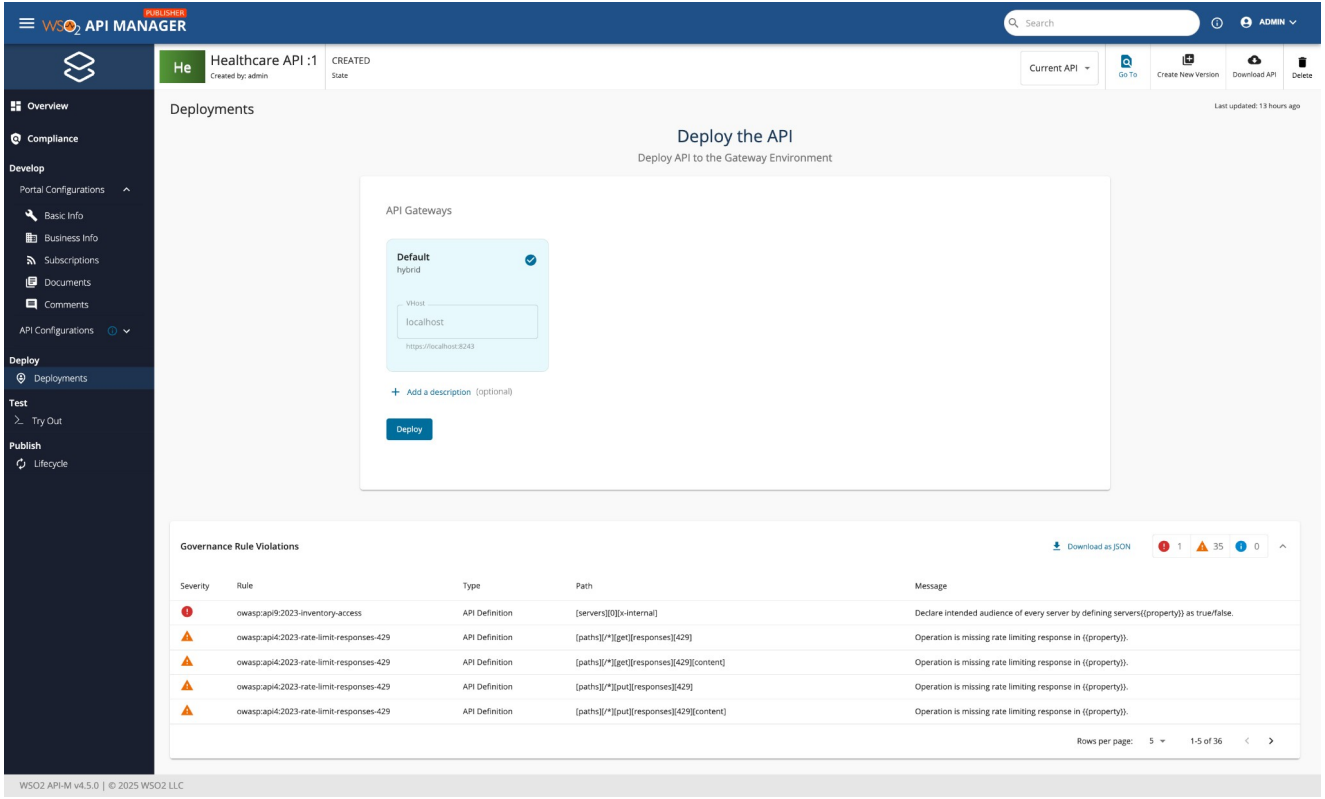
    Log in to the API Manager Publisher Portal https://localhost:9443/publisher

    Navigate to **API → Develop → Portal Configurations → Basic Info**

Dealing with Blocked API Operations

- If blocking governance policies are configured for API deployment and/or publishing, and the API violates those policies, the deployment will be blocked accordingly.
- If so, API creators or publishers must resolve all listed rule violations before attempting to redeploy or proceed.

Dealing with Blocked API Operations



Compliance Monitoring

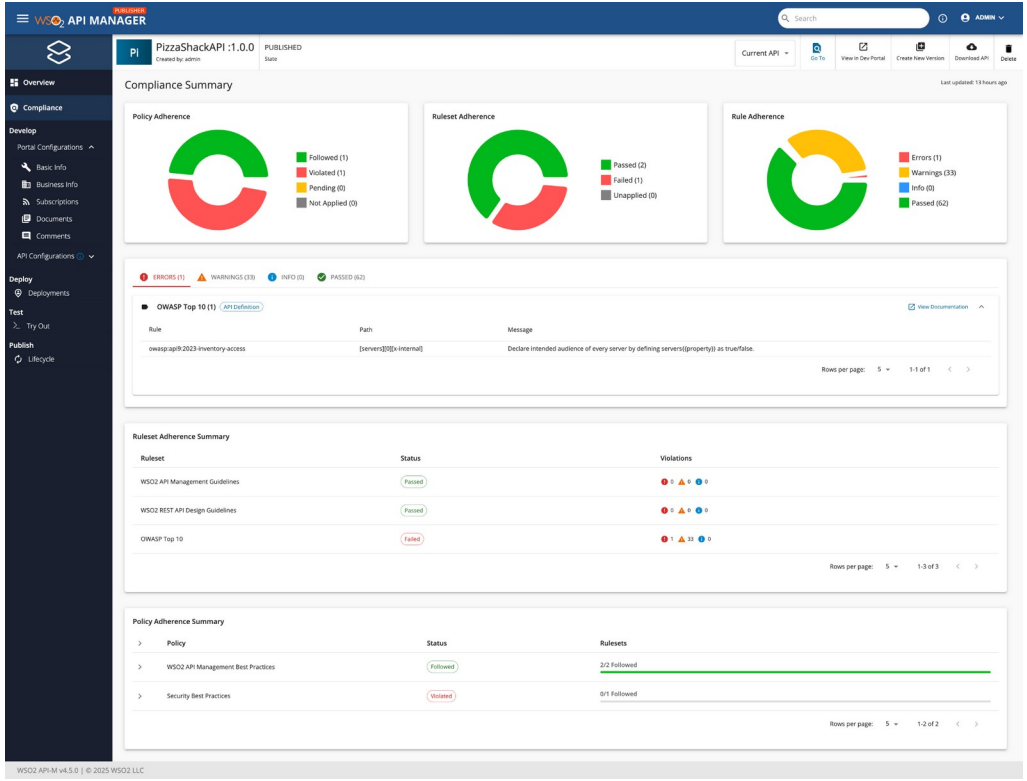
- Not all policies are configured to block developers; some are designed to evaluate compliance in the background.
- The compliance view under each API provides a comprehensive overview of its compliance status.
- To access this view,

    Log in to the API Manager Publisher Portal https://localhost:9443/publisher

    Select an API

    Navigate to the **Compliance** section from the left panel.

Compliance Monitoring



API Governance with WSO2 APICTL

API Governance with WSO2 APICTL

- APICTL now supports a **--dry-run** command to validate the API against the governance policies without actually importing the API.

  ```
  apictl import api --file <path-to-API-archive> --environment <environment> --dry-run
  ```

- This command can be integrated to CI/CD pipelines as required to evaluate governance for APIs without actually importing it to the API-M environment